# Care Access Navigator

## CloudSec1 Rubric — Criterion 6: Cloud Security Operations & Incident Response

*Evidence Package — Centralized Logging, VNet Flow Logs, Automated Alerting, Threat Detection (Microsoft Defender for Cloud), Security Dashboard and a Tested Incident-Response Playbook*


| | |
|---|---|
| **Prepared by:** | Akhila Chennamaneni |


| | |
|---|---|
| **Capstone:** | Care Access Navigator (HealthLine Regional Medical Center) |
| **Rubric criterion:** | Criterion 6 — Cloud Security Operations & Incident Response (CloudSec1) |
| **Environment:** | Microsoft Azure — Azure subscription 1 (rg-cloudsec1-can); Log Analytics, Azure Monitor, Network Watcher, Microsoft Defender for Cloud |
| **Evidence dates:** | October 8 and October 12, 2026 |

## Objective

This criterion requires centralized security logging (control-plane and network flow logs) with automated alerting, threat detection with a GuardDuty-class service, a security dashboard with key metrics, and an incident-response playbook covering identification, containment, investigation, eradication and recovery — **tested**, with evidence. Every capability below was built on CAN's live Azure environment and exercised with real events.

### Platform equivalents

| AWS (rubric) | Azure implementation in CAN |
|---|---|
| CloudTrail | Azure Activity Log exported to Log Analytics (8 categories) |
| VPC Flow Logs | VNet flow logs on both VNets + Traffic Analytics (10-minute processing) |
| CloudWatch Logs agent | Azure Monitor Agent + data collection rule (VM auth/authpriv/kern syslog) |
| CloudWatch alarms / EventBridge + SNS | Azure Monitor activity-log and log-search alerts → action group (email) |
| GuardDuty | Microsoft Defender for Cloud: Servers P2, Resource Manager, Storage (malware scanning) |
| CloudWatch dashboard / Security Hub | Azure Workbook 'CAN Security Operations Dashboard' |

**Cost:** Defender plans run on their 30-day free trial (ends 2026-11-07) and will be returned to Free before it ends; Log Analytics has a 0.15 GB/day cap to stay inside the free allowance; flow-log volume is a few MB. The VM was deallocated whenever it was not needed.

## Results at a Glance

| Requirement | Implementation | Verified result |
|---|---|---|
| Centralized logging (CloudTrail) | Activity Log → Log Analytics; VM auth logs via Azure Monitor Agent | **PASS** — attacker actions reconstructed with caller + IP |
| Flow logs (VPC Flow Logs) | VNet flow logs on 2 VNets, 7-day retention, Traffic Analytics | **PASS** — incident SSH flows captured; 3 real Internet scanners denied |
| Automated alerting | 7 activity-log alerts + SSH brute-force log alert → email | **PASS** — incident alerts fired ≈ 7.5 min after the change; brute-force alert fired |
| Threat detection (GuardDuty) | Defender for Cloud: Servers P2, Resource Manager, Storage | **PASS** — real malware upload detected in ~20 s; 43 sample alerts across 3 plans |
| Security dashboard | Azure Workbook: KPI tiles, alerts, SSH failures, changes, policy denials, flows | **PASS** — deployed; queries validated against live data |
| IR playbook, tested | NIST 800-61-aligned playbook; live incident INC-20261008-01 | **PASS** — contained in 11 min 45 s, recovered in 14 min; lessons-learned control verified |

# Part A — Centralized Logging

**STEP A1** 

### Control-plane audit log (CloudTrail equivalent)

A subscription diagnostic setting streams all eight Activity Log categories (Administrative, Security, Policy, Alert, Recommendation, ServiceHealth, ResourceHealth, Autoscale) into the Log Analytics workspace, giving a single, queryable record of every management-plane action with caller identity and source IP. Retention is 30 days with a daily ingestion cap as a cost guardrail.

**STEP A2** 

### Host security logs

The Azure Monitor Agent was installed on **can-vm-hardened** with a system-assigned managed identity, and data collection rule `dcr-can-vm-security-syslog` forwards the *auth*, *authpriv* and *kern* syslog facilities to the same workspace — so SSH authentication attempts and fail2ban bans are searchable centrally, not only on the host.

## STEP A3 VNet flow logs (VPC Flow Logs equivalent)

VNet flow logs (Azure's successor to NSG flow logs) were enabled on both CAN virtual networks, written to a tagged, TLS 1.2-only storage account in each region, retained 7 days, and processed by **Traffic Analytics** every 10 minutes. The raw records below were decoded from the flow-log blobs: they show the incident's SSH connections (matching the host log to the second) and three unknown Internet hosts whose SSH probes were **denied** by the `deny-all-inbound` rule.

**evidence/07-vnet-flowlog-ssh-records.txt**

```
== VNet flow log (fl-can-vnet-vmlab) - SSH (dst port 22) flows to can-vm-hardened, decoded from
    raw blobs
   total flow tuples in captured blobs: 877; port-22 tuples: 24
   time (UTC)           source           dest        port  dir  state     NSG rule
   2026-10-08 20:07:03  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-08 20:07:11  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-08 20:11:31  103.1.92.138     10.30.1.4   22    in   Denied    deny-all-inbound
   2026-10-08 20:11:32  103.1.92.138     10.30.1.4   22    in   Denied    deny-all-inbound
   2026-10-08 20:13:39  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-08 20:13:46  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-08 20:14:31  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-08 20:14:37  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-08 20:14:39  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-08 20:14:46  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-08 20:14:48  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-08 20:14:54  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-08 20:14:56  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-08 20:15:09  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-08 20:21:11  142.93.136.140   10.30.1.4   22    in   Denied    deny-all-inbound
   2026-10-08 20:28:03  62.60.130.219    10.30.1.4   22    in   Denied    deny-all-inbound
   2026-10-08 20:28:26  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-08 20:28:33  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-12 15:54:18  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-12 15:54:24  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-12 15:54:24  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-12 15:54:30  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   2026-10-12 15:54:31  24.189.77.111    10.30.1.4   22    in   Begin     allow-ssh-admin-ip
   2026-10-12 15:54:38  24.189.77.111    10.30.1.4   22    in   End       allow-ssh-admin-ip
   summary: 24.189.77.111 (admin) 10 allowed sessions via allow-ssh-admin-ip; 103.1.92.138,
    142.93.136.140, 62.60.130.219 (unknown Internet hosts) denied by deny-all-inbound
```

**Governance interaction:** Enabling Traffic Analytics was first **blocked by CAN's own tagging policy** (Criterion 5): the service auto-creates untagged data-collection endpoints. Instead of disabling the policy, a scoped, expiring **policy exemption** (Waiver) was created for the platform-managed monitoring resource group only, and a second (Mitigated) exemption covers Defender-managed VM extensions. Both exemptions are themselves watched by the `al-policy-exemption` alert.

**evidence/08-monitoring-configuration.txt**

```
== CAN security operations configuration (2026-10-12 16:11 UTC)

-- Centralized logging (CloudTrail equivalent): subscription Activity Log export
   can-activitylog-to-law   Administrative, Security, Policy, Alert, Recommendation,
    ServiceHealth, ResourceHealth, Autoscale
   destination: Log Analytics DefaultWorkspace-9a8c964b-...-EUS (retention 30 d, daily cap 0.15
    GB)

-- VNet flow logs (VPC Flow Logs equivalent)
   fl-can-vnet-cloudsec1    vnet=can-vnet-cloudsec1   enabled=True retention=7d
    trafficAnalytics=True every 10 min
   fl-can-vnet-vmlab        vnet=can-vnet-vmlab       enabled=True retention=7d
    trafficAnalytics=True every 10 min

-- Host log collection
   Azure Monitor Agent on can-vm-hardened; DCR dcr-can-vm-security-syslog: syslog auth, authpriv,
    kern -> Log Analytics

-- Threat detection (GuardDuty equivalent): Microsoft Defender for Cloud
   VirtualMachines  P2  26 days, 3:48:00
   StorageAccounts  DefenderForStorageV2    26 days, 3:48:00
   Arm  PerSubscription 26 days, 3:48:00
   Defender for Storage extensions: on-upload malware scanning (cap 1 GB/account/month), sensitive
     data discovery
   Email notifications: alerts >= Medium to subscription owner; continuous export of alerts to Log
     Analytics

-- Alerting (action group ag-can-secops -> email)
   al-nsg-rule-change         enabled=True  Firewall (NSG) rule created or modified
   al-nsg-rule-delete         enabled=True  Firewall (NSG) rule deleted
   al-role-assignment         enabled=True  New Azure RBAC role assignment (privilege change)
   al-policy-assignment-del   enabled=True  Governance policy assignment removed
   al-policy-exemption        enabled=True  Policy exemption created or changed
   al-storage-listkeys        enabled=True  Storage account keys retrieved
   al-defender-alert          enabled=True  Microsoft Defender for Cloud raised a security alert
   sqr-ssh-bruteforce         enabled=True  log query every 0:15:00 over 0:30:00 window, Sev2:
    total FailedAttempts > 1

-- Dashboard: Azure Workbook 'CAN Security Operations Dashboard' (rg-cloudsec1-can)
```

# Part B — Automated Alerting

| Alert rule | Fires on | Why it matters |
|---|---|---|
| al-nsg-rule-change / -delete | Any NSG rule write or delete (incl. attempts) | Firewall backdoors, exposure |
| al-role-assignment | New RBAC role assignment | Privilege escalation / persistence |
| al-policy-assignment-del | Governance policy removed | Defence evasion |
| al-policy-exemption | Policy exemption created or changed | Guardrail bypass |
| al-storage-listkeys | Storage account keys retrieved | Credential access to PHI stores |
| al-defender-alert | Any Defender for Cloud alert | Threat detection hand-off |
| sqr-ssh-bruteforce | Total failed/blocked SSH auths > 1 in 30 min (every 15 min) | Brute force on hosts |

All rules notify action group **ag-can-secops** (email to the subscription owner) using the common alert schema; Defender for Cloud additionally emails alerts of Medium severity and above.

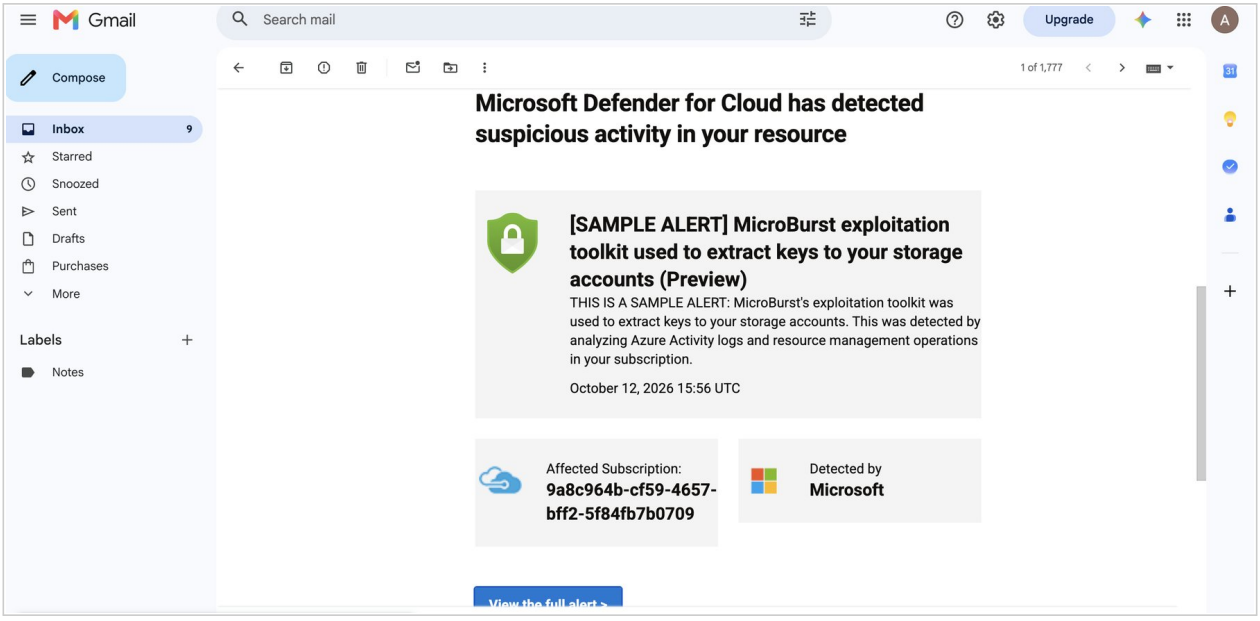



*Figure 1. Alert delivery — Defender for Cloud email received by the security contact on 2026-10-12 (sample Resource Manager alert used to validate the notification path).*

## STEP B1 Fixing the brute-force alert (found during testing)

On October 8 the brute-force rule did not fire. Testing on October 12 found two defects: (1) the 15-minute window was shorter than the ~4-minute ingestion delay, so events fell between evaluations; and (2) the condition counted *result rows*, but the query returns one row per host, so the threshold > 1 could never be met. The window was widened to 30 minutes (overlapping evaluations) and the condition changed to **total FailedAttempts > 1**.

**evidence/05-bruteforce-retest.txt**

```
== Brute-force detection re-test (2026-10-12) — alert window widened to 30 min to absorb ~4 min
    ingestion latency
[2026-10-12 15:54:18 UTC] SSH attempt as 'root' -> root@64.236.131.161: Permission denied
    (publickey).
[2026-10-12 15:54:25 UTC] SSH attempt as 'admin' -> admin@64.236.131.161: Permission denied
    (publickey).
[2026-10-12 15:54:31 UTC] admin SSH still works (below fail2ban threshold): yes
[2026-10-12 16:10:20 UTC] Rule condition corrected: was 'count of result rows > 1' (query returns
    1 row per host, so it could never fire); now 'total FailedAttempts > 1'
[2026-10-12 16:10:21 UTC] SSH attempt as 'root' -> root@64.236.131.161: Permission denied
    (publickey).
[2026-10-12 16:10:27 UTC] SSH attempt as 'admin' -> admin@64.236.131.161: Permission denied
    (publickey).

[2026-10-12 16:24:28 UTC] ALERT FIRED: sqr-ssh-bruteforce  Sev2  state=Fired  target=Log Analytics
     workspace (first evaluation after the fix; failed attempts at 15:54 and 16:10)
```

# Part C — Threat Detection (GuardDuty equivalent)

Microsoft Defender for Cloud is Azure's closest equivalent to GuardDuty: **Defender for Resource Manager** analyses control-plane operations (as GuardDuty analyses CloudTrail), **Defender for Storage** detects malicious uploads and anomalous access (GuardDuty S3/Malware Protection), and **Defender for Servers P2** provides host threat detection and vulnerability assessment.

## STEP C1 Real detection — malware uploaded to PHI storage

The industry-standard EICAR antivirus test file was uploaded to the function's storage account. Defender for Storage's on-upload malware scanning raised a **High** alert about 20 seconds later, which was emailed and routed to the `al-defender-alert` rule.

**evidence/09-defender-detections.txt**

```
== Microsoft Defender for Cloud detections (Defender alerts API, 44 alerts)

-- REAL detections
   Time:      2026-10-08T20:05:22.060000+00:00
   Alert:     Malicious blob uploaded to storage account
   Severity:  High
   Resource:  stcanfunc9a8c964b
   Type:      Storage.Blob_AM.MalwareFound
   Intent:    LateralMovement
   Detail:    A malicious blob was uploaded to your storage account 'stcanfunc9a8c964b'.
The detected malware type is 'Virus:DOS/EICAR_Test_File'.
This security alert was generated by the Malware Scanning feature in Defender for Storage.
Potential causes may include an intentional upload of malware by a threat

   Trigger: EICAR antivirus test file uploaded 2026-10-08 20:05 UTC to
    stcanfunc9a8c964b/malware-test/eicar-test.txt

-- Pipeline validation: official Defender sample alerts by plan (2026-10-08 and 2026-10-12)
   Plan               Alerts  High  First generated (UTC)
   Resource Manager   8       2     2026-10-08 20:04:57
   Servers (P2)       9       3     2026-10-08 20:04:57
   Storage            26      10    2026-10-08 20:04:58
```

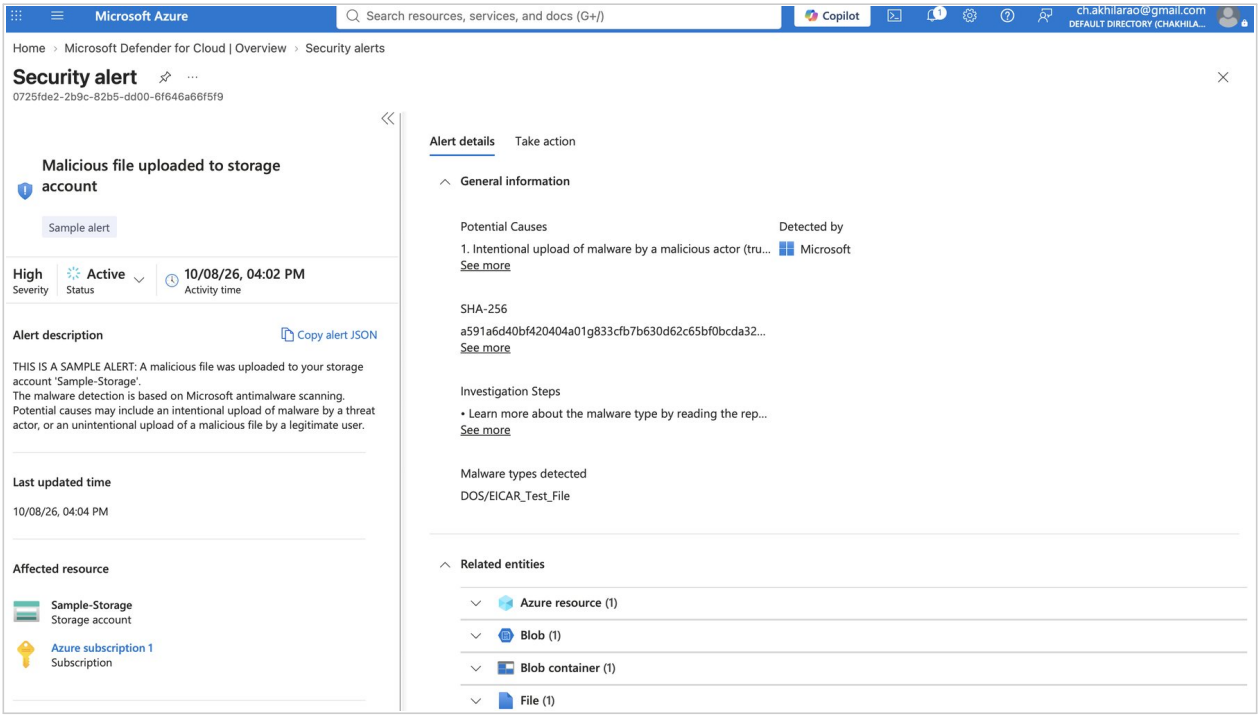



*Figure 2. Defender for Cloud portal — a **sample** storage malware alert (DOS/EICAR_Test_File) from the pipeline-validation bundle. The **real** detection on stcanfunc9a8c964b is shown in the evidence output above.*

# Part D — Security Dashboard

The Azure Workbook **CAN Security Operations Dashboard** (definition saved in `can-secops/config/`) combines Log Analytics and Azure Resource Graph queries:

| Panel | Source | Key metric |
|---|---|---|
| Key security metrics (tiles) | AzureActivity, Syslog | NSG changes, key retrievals, policy denials, RBAC grants, failed SSH auths |
| Defender alerts by severity / latest 25 | Resource Graph (securityresources) | Open threats and triage list |
| Failed SSH authentications over time | Syslog (Azure Monitor Agent) | Brute-force trend per host |
| Security-relevant control-plane changes | AzureActivity | Who changed what, from which IP |
| Requests blocked by Azure Policy | AzureActivity (policies/deny) | Guardrail effectiveness |
| Network flows by status; top sources to port 22 | NTANetAnalytics (VNet flow logs) | Allowed vs denied, scanning sources |
| Policy compliance per assignment | Resource Graph (policyresources) | Non-compliant resources |

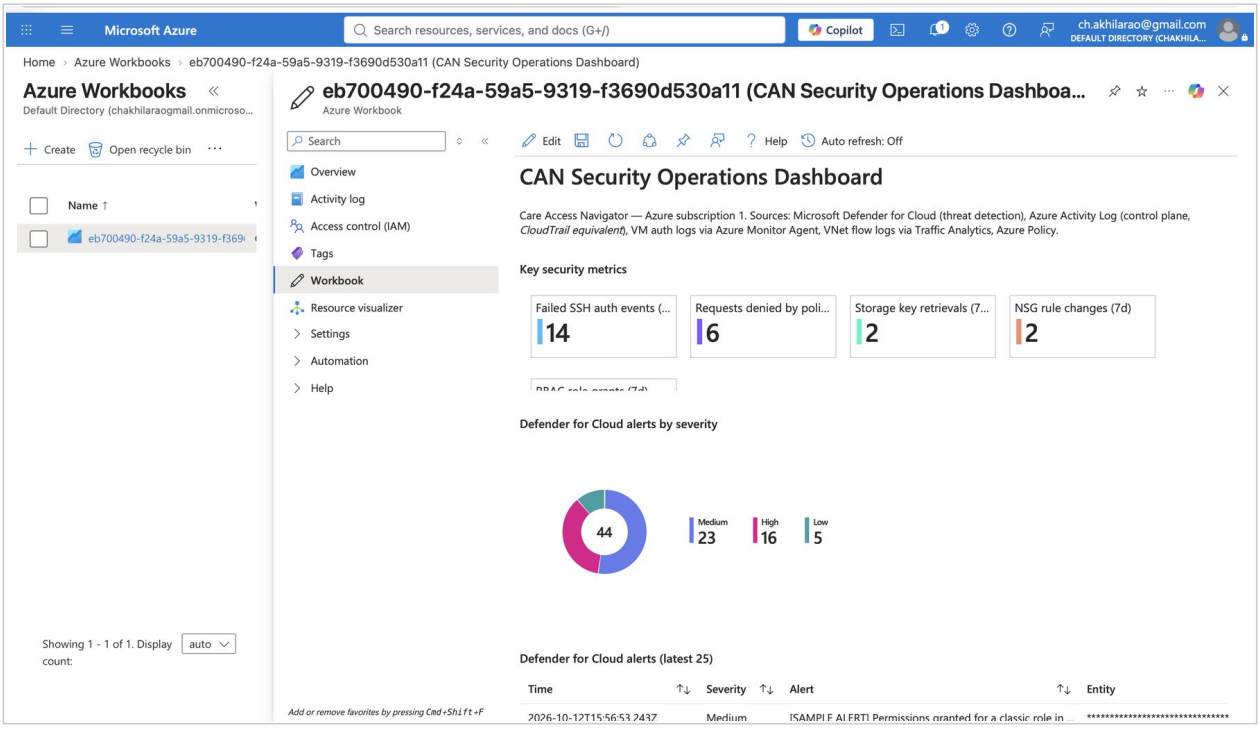



*Figure 3. Azure portal — CAN Security Operations Dashboard (live): 14 failed SSH auth events, 6 policy denials, 2 storage key retrievals, 2 NSG rule changes; 44 Defender alerts (16 High).*

# Part E — Incident Response Playbook

The playbook (`can-secops/IR-Playbook.md`) follows NIST SP 800-61r2 and HIPAA §164.308(a)(6). It defines severities with response targets and HIPAA breach escalation, the alert sources, and concrete Azure commands and KQL for each phase:

| Phase | Key actions in the CAN playbook |
|---|---|
| Identification | Open alert; record time, resource, caller/IP; rule out approved change; assign severity and incident ID |
| Containment | Delete rogue NSG rules; rely on/extend fail2ban bans; rotate storage keys; disable compromised identities; preserve evidence first |
| Investigation | KQL over AzureActivity (who/what/where), Syslog (host auth), NTANetAnalytics / raw flow logs (network), SecurityAlert (Defender) |
| Eradication | Remove every attacker artefact; rotate exposed credentials; rescan policy; search all operations by the attacker identity/IP |
| Recovery | Restore approved baseline; verify service and monitoring; heightened monitoring for 7 days |
| Lessons learned | Timeline, root cause, MTTD/MTTR, and at least one new preventive control |

| Severity | Examples | Response start |
|---|---|---|
| SEV-1 Critical | Confirmed PHI exposure, malware on host, attacker with Owner | Immediately (+ Privacy Officer) |
| SEV-2 High | Firewall opened, unexpected key retrieval, new Owner | < 1 hour |

| Severity | Examples | Response start |
|---|---|---|
| SEV-3 Medium | Blocked brute force, policy exemption created | < 1 business day |
| SEV-4 Low | Single failed login, informational recommendation | Next review |

## Part F — Playbook Test: INC-20261008-01

**Scenario:** an insider-style attacker with stolen admin credentials (1) adds a backdoor firewall rule allowing SSH to the VM, (2) retrieves storage account keys, and (3) brute-forces SSH with common account names. The blue team then executed the playbook end to end.

> **Safety:** For safety, the simulated backdoor rule allowed SSH only from 203.0.113.66 — an RFC 5737 documentation address that cannot exist on the Internet — rather than from any source. It produces exactly the same control-plane event and alert, with zero real exposure.

### STEP F1 Attack simulation

**evidence/01-attack-simulation.txt**

```
== INC-20261008-01 attack simulation (red team actions)
   Note: the 'attacker' source is 203.0.113.66 (RFC 5737 documentation range, unroutable) so the
   simulated backdoor rule creates no real exposure.
[2026-10-08 20:14:27 UTC] T0 START
[2026-10-08 20:14:29 UTC] A1 rogue NSG rule 'allow-ssh-backdoor' (22/tcp from 203.0.113.66) added
    to vm-sg
[2026-10-08 20:14:31 UTC] A2 storage account keys listed for stcanflowncu9a8c
[2026-10-08 20:14:31 UTC] A3 SSH attempt as 'root' -> root@64.236.131.161: Permission denied
    (publickey).
[2026-10-08 20:14:40 UTC] A3 SSH attempt as 'admin' -> admin@64.236.131.161: Permission denied
    (publickey).
[2026-10-08 20:14:48 UTC] A3 SSH attempt as 'oracle' -> oracle@64.236.131.161: Permission denied
    (publickey).
[2026-10-08 20:14:56 UTC] A4 legitimate admin SSH after brute force -> refused/timed out (fail2ban
     ban in effect)
```

### STEP F2 Identification — alerts fired

**evidence/02-alerts-fired.txt (Azure Monitor alerts)**

```
20:22:00  al-nsg-rule-change       Sev4 allow-ssh-backdoor
20:22:00  al-nsg-rule-change       Sev4 allow-ssh-backdoor
20:22:00  al-nsg-rule-change       Sev4 allow-ssh-backdoor
20:22:01  al-storage-listkeys      Sev4 stcanflowncu9a8c
20:22:01  al-storage-listkeys      Sev4 stcanflowncu9a8c
```

## STEP F3 Containment, eradication and recovery

**evidence/03-response-log.txt**

```
== INC-20261008-01 response log (blue team)
[2026-10-08 20:22:00 UTC] I1 IDENTIFIED: al-nsg-rule-change + al-storage-listkeys fired (email to
    secops-owner). Severity SEV-2 assigned.
[2026-10-08 20:26:08 UTC] C1 CONTAIN: NSG vm-sg rules before containment:
      100   allow-ssh-admin-ip  24.189.77.111/32    22  Allow
      4000  deny-all-inbound    *   *   Deny
      110   allow-ssh-backdoor  203.0.113.66/32 22  Allow
[2026-10-08 20:26:12 UTC] C2 CONTAIN: rogue rule allow-ssh-backdoor deleted
[2026-10-08 20:26:14 UTC] C3 ERADICATE: both access keys of stcanflowncu9a8c rotated (listed keys
    now invalid)
[2026-10-08 20:26:14 UTC] C4 CONTAIN (automatic, host): fail2ban ban of brute-force source remains
     active
[2026-10-08 20:28:08 UTC] R1 RECOVER: admin IP released from fail2ban via Azure Run Command
    (out-of-band, no SSH needed)
      --- fail2ban log
      2026-10-07 15:54:57,086 fail2ban.filter         [648]: INFO    [sshd] Found 24.189.77.111 -
    2026-10-07 15:54:57
      2026-10-07 15:55:09,794 fail2ban.filter         [648]: INFO    [sshd] Found 24.189.77.111 -
    2026-10-07 15:55:09
      2026-10-08 20:14:31,937 fail2ban.filter         [641]: INFO    [sshd] Found 24.189.77.111 -
    2026-10-08 20:14:31
      2026-10-08 20:14:40,088 fail2ban.filter         [641]: INFO    [sshd] Found 24.189.77.111 -
    2026-10-08 20:14:40
      2026-10-08 20:14:48,556 fail2ban.filter         [641]: INFO    [sshd] Found 24.189.77.111 -
    2026-10-08 20:14:48
      2026-10-08 20:14:49,284 fail2ban.actions        [641]: NOTICE  [sshd] Ban 24.189.77.111
      --- jail before
         |- Currently banned:   1
         |- Total banned:   1
         `- Banned IP list: 24.189.77.111
      1
      --- jail after
         |- Currently banned:   0
         `- Banned IP list:

[2026-10-08 20:28:25 UTC] R2 VERIFY baseline - vm-sg rules now:
      100   allow-ssh-admin-ip  24.189.77.111/32    22  Allow
      4000  deny-all-inbound    *   *   Deny
[2026-10-08 20:28:26 UTC] R3 VERIFY admin SSH: ok from can-vm-hardened
[2026-10-08 20:28:27 UTC] R4 VERIFY function ehr-status: HTTP 200
[2026-10-08 20:28:32 UTC] R5 VERIFY flow logs enabled: fl-can-vnet-vmlab=True
[2026-10-08 20:28:33 UTC] R6 VERIFY alert rules enabled: 7 activity-log alerts +
    sqr-ssh-bruteforce=true
```

## STEP F4 Investigation

**evidence/04-investigation.txt (Log Analytics KQL)**

```
== INVESTIGATION  (Log Analytics queries run 20:26 UTC)

-- Q1 Control-plane changes in the incident window (AzureActivity)
  Time      Operation            Resource            Caller                  CallerIpAddress
  20:14:29  SECURITYRULES/WRITE  allow-ssh-backdoor  ch.akhilarao@gmail.com  24.189.77.111
  20:14:30  LISTKEYS/ACTION      stcanflowncu9a8c    ch.akhilarao@gmail.com  24.189.77.111

-- Q2 Host authentication events on can-vm-hardened (Syslog)
  Time      Process  Message
  20:14:31  sshd     User root from 24.189.77.111 not allowed because not listed in AllowUsers
  20:14:31  sshd     Connection closed by invalid user root 24.189.77.111 port 57750 [preauth]
  20:14:40  sshd     Invalid user admin from 24.189.77.111 port 57752
  20:14:40  sshd     Connection closed by invalid user admin 24.189.77.111 port 57752 [preauth]
  20:14:48  sshd     Connection closed by invalid user oracle 24.189.77.111 port 57753 [preauth]
  20:14:48  sshd     Invalid user oracle from 24.189.77.111 port 57753

-- Q3 Persistence check: all successful operations from the source IP in the window
  Operation                                                  Count
  MICROSOFT.STORAGE/STORAGEACCOUNTS/LISTKEYS/ACTION          1
  MICROSOFT.NETWORK/NETWORKSECURITYGROUPS/SECURITYRULES/WRITE  1
```

## STEP F5 Timeline and response metrics

| Time (UTC) | Event | Elapsed |
|---|---|---|
| 20:14:27 | Attack starts | 0:00 |
| 20:14:29 | Backdoor NSG rule created (A1) | 0:02 |
| 20:14:31 | Storage keys listed (A2) | 0:04 |
| 20:14:49 | fail2ban bans brute-force source (automatic host containment) | 0:22 |
| 20:22:00 | Activity-log alerts fire — **MTTD ≈ 7 min 31 s** | 7:33 |
| 20:26:12 | Backdoor rule removed — **contained** | 11:45 |
| 20:26:14 | Both storage keys rotated (eradication) | 11:47 |
| 20:28:08 | Admin access restored (fail2ban unban via Run Command) | 13:41 |
| 20:28:27 | Baseline, SSH, function and monitoring verified — **recovered** | 14:00 |

STEP F6

### Lessons learned — new preventive control, verified

**Root cause:** nothing prevented an administrator identity from adding an inbound SSH rule from an arbitrary source; detection worked, prevention did not. **Corrective action:** a new custom Azure Policy, *CAN – Management ports (SSH/RDP) only from approved admin IPs*, was assigned at the top management group with the Deny effect. Replaying the attacker's first step was then **denied**, while the same rule from the approved admin IP still validates.

**evidence/06-lessons-learned-control-test.txt**

```
== Lessons-learned control re-test (2026-10-12)
   Policy 'CAN - Management ports only from approved admin IPs' assigned at mg-can 15:55:19 UTC
[2026-10-12 15:55:39 UTC] Replay INC-20261008-01 step A1: add SSH rule from 203.0.113.66 to vm-sg
   DENIED  | assignment: CAN - Management ports only from approved admin IPs
   message : INC-20261008-01 control: inbound SSH/RDP may only be opened to approved admin IP
    prefixes. Request an exception from Cloud Security.
[2026-10-12 15:55:41 UTC] Control: same rule from the APPROVED admin IP (validate only)
   validate: Succeeded
```

- Detection latency (≈ 7.5 min) is set by Activity Log delivery; Defender alerts arrived in ~20 s. For faster response, an automated containment Logic App on al-nsg-rule-change is a candidate next step.
- The brute-force rule defects (B1) were found only by testing — alert rules now get a test event after every change.
- fail2ban banned the administrator's own IP during the test; out-of-band recovery through Azure Run Command worked and is now part of the playbook.

## Issues Encountered

| Issue | Resolution |
|---|---|
| Traffic Analytics blocked by CAN's mandatory-tag policy | Scoped, expiring Waiver exemption for the platform-managed monitoring RG |
| Defender sample-alert API rejected the default region (westcentralus) and the body format | Used the centralus endpoint and the correct properties.kind body |
| Brute-force alert did not fire (window shorter than ingestion delay; row-count condition) | 30-min window, 'total FailedAttempts > 1'; re-tested |
| Opening SSH to any source for the test was refused by the operator's safety controls | Used an RFC 5737 documentation address — same detection path, no exposure |
| Defender continuous export did not populate SecurityAlert in the workspace | Dashboard reads Defender alerts from Azure Resource Graph instead (always current) |

### Compliance Mapping

| Control | HIPAA Security Rule | NIST CSF 2.0 | Evidence |
|---|---|---|---|
| Centralized audit logging | §164.312(b) Audit controls | DE.CM-01, DE.CM-09 | Part A |
| Activity review & alerting | §164.308(a)(1)(ii)(D) | DE.AE-02, DE.AE-06 | Part B |
| Threat detection | §164.308(a)(5)(ii)(B) | DE.CM-01, DE.AE-02 | Part C |

| Control | HIPAA Security Rule | NIST CSF 2.0 | Evidence |
|---|---|---|---|
| Incident procedures | §164.308(a)(6)(i)–(ii) | RS.MA-01, RS.AN-03, RS.MI-01 | Parts E–F |
| Recovery & improvement | §164.308(a)(7) | RC.RP-01, ID.IM-03 | Part F (F5–F6) |

## Implementation Status

**Implemented & verified:** Activity Log and host logs centralized in Log Analytics; VNet flow logs with Traffic Analytics on both VNets; eight automated alert rules; Defender for Cloud threat detection across servers, control plane and storage with a real malware detection; security dashboard; NIST-aligned playbook tested end to end with measured MTTD/MTTR and a verified lessons-learned control. This work closes Criterion 5 HIPAA gaps A3 (activity review) and A8 (incident procedures) and partly T3 (audit controls: Activity Log and host logs are centralized; per-resource diagnostic settings remain planned). Evidence is stored in `can-secops/`.